



PROJECTEMAIL / FROM ZERO TO TRUSTED UTILITY

Two-Track Build, Design, SEO, GEO & Market Roadmap

A detailed, policy-aware execution plan for two GitHub collaborators building a disposable email platform from scratch.

TRACK A	TRACK B
Platform, mail, security, data, reliability	Product design, frontend, search, GEO, growth, monetization

Inputs: investor plan PDF, live GitHub Pages site, current ProjectEmail repository, official search/publisher/platform guidance. This report distinguishes source-plan instructions from the requested strategy and corrects unsafe or unsupported assumptions.

SECTION 01

Executive decision

Build the utility first, prove discovery and monetization second, scale only from measured evidence.

The proposed business is viable as a focused privacy and testing utility, but the original plan is not safe to execute literally. The strongest opportunity is a fast, trustworthy inbox with excellent OTP handling, a developer API, and high-quality educational content. The biggest risk is assuming that traffic and ad yield follow automatically from page volume.

Recommended operating thesis

Win on **speed, trust, OTP accuracy, mobile usability, transparent privacy, and developer utility**. Use content and integrations to earn distribution. Treat display advertising as an experiment on eligible content routes - never as the only economic assumption.

Decision	Recommendation	Why it matters
MVP stack	Keep the repository's FastAPI + Next.js + Neon design; use one process for the MVP event broker and add Redis before horizontal scale.	Matches code already shipped and avoids a premature platform rewrite.
Mail ingest	Use an inbound provider webhook for the first public pilot; validate dedicated Postfix/LMTP only after reliable demand.	Render/GitHub Pages cannot accept public SMTP port 25.
SEO	Launch 12 cornerstone pages + 20-40 reviewed use-case/support pages, then expand only if indexation and engagement pass gates.	Avoids doorway and scaled-content abuse risk [S1-S3].
GEO / AI	Use crawlable, answer-first, cited pages and allow OAI-SearchBot. There is no separate GEO approval or guaranteed AI recommendation.	Google and Bing say standard quality/discovery foundations apply to AI results [S3, S6, S7].
Ads	Route-split. No Google ads on the inbox, message viewer, or extension. Test Google demand only on substantive publisher-content routes.	AdSense bars ads where email/private communication is primary [S8].
Revenue	Use an evidence-based scenario model and affiliate/direct sponsorship experiments; do not present \$279k/month as a forecast.	eCPM, adblock, geography, eligible route share, and approvals dominate results.

Definition of success at week 24

- + A reliable inbox on three domains with end-to-end p95 mail arrival below 2 seconds after provider acceptance.
- + Possession-token reads, isolated email rendering, no message-body logging, deletion/expiry tested, and an abuse runbook in production.
- + At least 25 high-quality indexed pages, 80%+ valid indexation in the pilot cohort, and evidence of non-branded search impressions.
- + Chrome extension submitted only after it provides native inbox utility; not a page launcher and not an ad wrapper [S12].
- + Written ad-route determination or a functioning non-Google/affiliate path; no monetization code on prohibited routes.

SECTION 02

What changes from the source plan

The plan is an input, not an instruction set. These corrections are required before implementation.

Source-plan claim	Risk / evidence	Replacement decision
2,000 pages x 25 languages immediately	Near-duplicate query pages can match doorway or scaled-content abuse; automated translations without added value are specifically risky [S1-S3].	Pilot 32-52 pages total. Expand one cluster or locale at a time after native review and performance gates.
Google ads beside the inbox	AdSense policy prohibits placements where email messages or private communication are the primary focus [S8].	No Google code on /inbox, /message, or sandbox routes. Monetize content pages; obtain written guidance for any other demand.
35-45 second automatic refresh	Refreshing inventory in GAM must be declared accurately; longer intervals are generally more desirable. AdSense is not a substitute for GAM declarations [S9].	Default to no timer refresh. If an approved GAM/MCM partner allows it, declare the exact trigger and run controlled tests.
Extension opens a monetized framed site	Chrome requires useful native functionality, a narrow purpose, clear disclosure, minimum permissions, and rejects mere launchers/ad wrappers [S12].	Native popup creates and monitors an inbox; an optional button opens the full site. No AdSense inside the extension.
allow-same-origin email iframe	Untrusted email must never receive a path back to the app origin; combining same-origin and scripts defeats sandboxing.	Serve sanitized HTML from a separate sandbox origin with no scripts; allow safe link popups only.
Rotating domains as anti-block evasion	Framing rotation as evasion creates trust, provider, and abuse-governance risk.	Manage mail domains as reliability inventory: warm, monitor, drain, retire. Keep one permanent brand/SEO domain.
95%+ net margin / \$279k monthly	The model omits adblock, ineligible inbox routes, MCM share, consent loss, fraud deductions, support, legal, and domain operations.	Use measured eligible sessions x served impressions x net eCPM plus verified affiliate revenue; publish ranges, not a single promise.
Serverless automatically scales to 100M	Mail ingress, held SSE connections, provider limits, abuse, and cost controls do not scale automatically.	Scale at explicit load gates. Add Redis, multi-worker fanout, queueing, and dedicated SMTP only when thresholds require them.

Non-negotiable constraints

- + Inbound only. No send, reply, forwarding, SMTP client, or feature that can become a relay.
- + Generated addresses carry at least 64 bits of entropy; reading also requires a possession token.
- + Unknown or expired inbox mail is dropped before expensive parsing or storage.
- + Messages expire quickly and are never used for targeting, personalization, or content generation.
- + Ad/analytics scripts load only after the applicable consent signal; privacy/legal pages load without consent-gated scripts [S11].

SECTION 03

Current starting point audit

Baseline after pulling GitHub main at commit 6653b14 on 27 August 2026.

Area	Current state	Immediate implication
Live site	GitHub Pages shows a polished placeholder: ProjectEmail label, welcome headline, short promise, and 'inbox UI coming' status.	Treat it as a deployment proof, not a product launch. Replace before marketing or ad applications.
Frontend	Next.js 15 static-export target for Pages; simple single page; strict TypeScript; Tailwind v4.	Build crawlable public routes statically. The live inbox remains client-driven against the API.
Backend	FastAPI endpoints for inbox create/read, message detail, SSE, and inbound webhook. Possession-token checks and expiry filters exist.	Good contract foundation; add deletion, rate limiting, provider signature verification, and end-to-end tests.
Data	Neon Postgres has domain/API-key/inbox/message models and migrations. MVP ADR stores temporary messages in Postgres.	Safe only at MVP scale; add a deletion scheduler and watch compute/write costs.
Events	In-process asyncio event broker; one-process constraint documented.	WEB_CONCURRENCY must stay 1 until Redis/pub-sub replacement lands.
Deployment	Static frontend on Pages, Render blueprint for API, Neon connected; public SMTP and sandbox origin are not complete.	The first infrastructure decision is the inbound provider/webhook and separate content-sandbox host.
Documentation	Strong security, validation, architecture, database, and roadmap docs; some deployment text still references Redis despite the new MVP ADR.	Resolve doc drift before onboarding contributors or running production checklists.
Brand/design	Current page is neutral white/gray/green and intentionally minimal.	Evolve it into an independent ProjectEmail product system that keeps the repository's clean spacing, neutral surfaces, and privacy-oriented green accent.

Critical first dependencies

Dependency	Owner	Decision deadline	Evidence required
Inbound provider accepts disposable-email use case	A	Week 0	Written acceptance, webhook signing method, payload/size limits, pricing.
Brand domain and sandbox domain	Shared	Week 0	Registrant ownership, recovery access, DNS plan, no MX on brand domain.
Ad route eligibility	B	Week 1	Written response from Google/MCM/GCPP; acceptable page examples.
Operating entity / privacy jurisdiction	Shared	Week 1	Counsel memo on consent, retention, requests, abuse, and processor terms.
Custom domain for public site	B	Week 2	HTTPS, canonical origin, Search Console ownership.

SECTION 04

Model-tier execution map

Use high-tier reasoning for architecture once; use balanced and lightweight tiers for the recurring implementation work.

Subtask	Tier	Use rule	Human review
Threat model, mail-ingest topology, multi-origin sandbox, data-retention design, ad-route policy architecture	5.6 Sol	Architecture and zero-error planning only; produce ADRs and testable acceptance criteria.	Both collaborators approve before code.
From-scratch responsive information architecture and production UI system	5.6 Sol	Initial product/design system and hard interaction constraints.	Track B owns; Track A reviews security contracts.
FastAPI routes, SQLAlchemy services, Next.js components, migrations, API integrations, refactors	5.6 Terra	Default routine engineering after ADRs are approved.	Opposite track reviews PR.
Unit/integration tests and moderate debugging	5.6 Terra	Use repository patterns and run full affected suite.	Owner verifies failures before fixes.
Copy formatting, metadata variants, simple regex drafts, changelogs, routine docs	5.6 Luna / 5.4 Mini	High-frequency low-risk work; never decide policy/security architecture.	Track B edits user copy; Track A validates regex tests.
Final security, privacy, ad-policy, migration, and DNS changes	5.6 Sol review	Review the completed diff and failure modes before merge.	Two-person approval required.

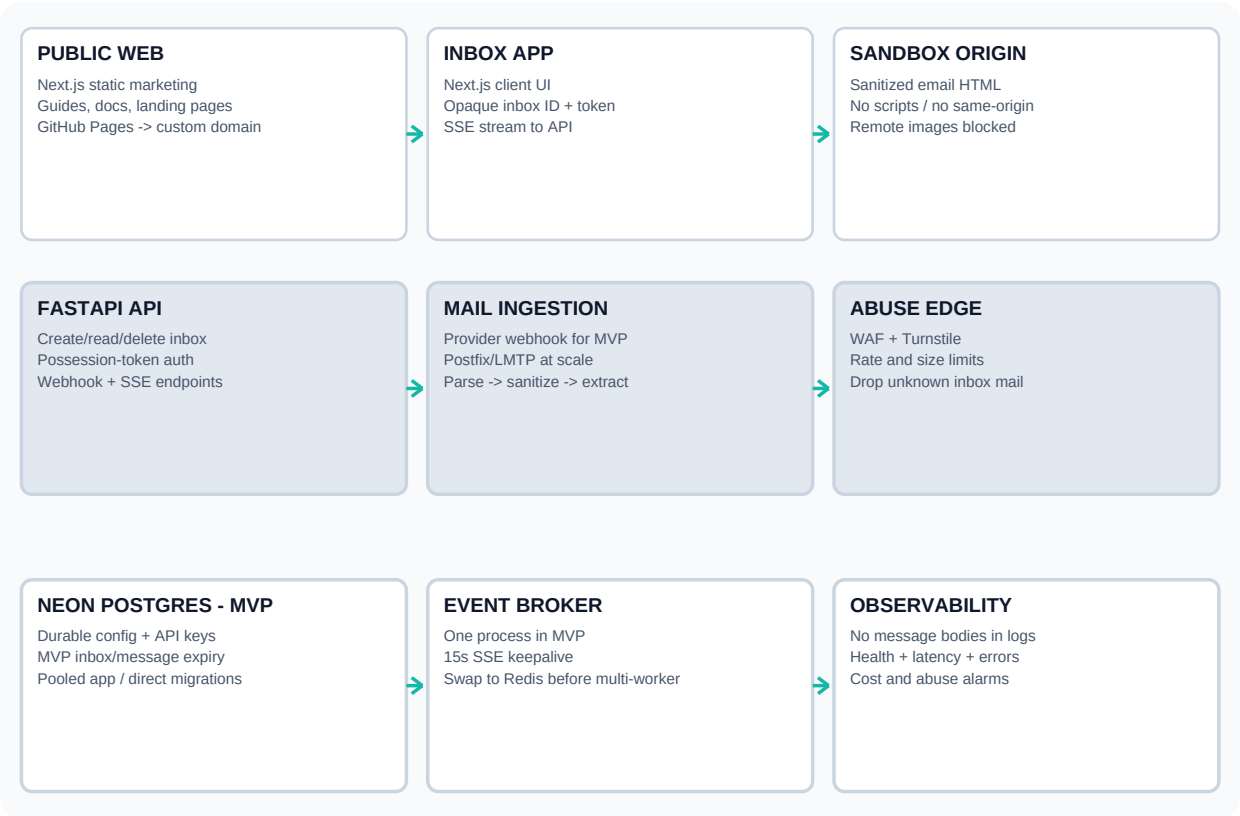
Routing principle

The model tier does not change accountability. Every production change must be tied to an issue, a small PR, tests, and a named human reviewer. AI never approves its own security or policy-sensitive work.

SECTION 05

Recommended product architecture

Keep the repository's direction, but make scale boundaries explicit.



Stage	Traffic shape	Architecture	Promotion gate
Prototype	Team + testers	Pages preview, Render API, Neon; provider webhook; one worker; Postgres TTL fields.	Real provider mail arrives safely; no secrets in client; sandbox origin live.
Public MVP	Up to ~10k monthly active users	Paid no-cold-start API; one worker; scheduled expiry deletion; WAF/rate limits; provider limits monitored.	p95 delivery <2s, error budget met, no enumeration findings.
Growth	Need >1 worker or sustained write pressure	Redis TTL/pub-sub/counters, multi-worker API, background jobs, queue backpressure, load-tested SSE.	Cross-worker delivery test; cost per 1k inboxes known.
Scale	Millions of sessions / large domain pool	Dedicated ingress and queue, regional API/SSE, durable telemetry, automated domain health and incident operations.	Capacity, abuse, legal, and unit economics all pass monthly review.

SECTION 06

Security, privacy, abuse and compliance

A privacy utility earns attention only if the trust story is visible and technically true.

Required security controls

Threat	Control	Acceptance test
Inbox enumeration / OTP theft	>=64-bit local-part entropy plus opaque inbox ID and possession token; identical 404 for missing/bad token.	Automated tests reject address-only reads; fuzz 1M generated addresses with no collision.
Malicious email HTML	Parse -> strict sanitize -> separate sandbox origin; no scripts; remote images blocked; warning/interstitial for links.	CSP and iframe test suite blocks script, form, frame, same-origin access, tracking image.
Webhook forgery	Provider signature verification, timestamp window, replay key, size cap, recipient normalization.	Invalid signature/replay returns 401/409 before parsing or writes.
Denial of wallet	Edge rate limits, Turnstile on suspicious creation, message/inbox caps, drop unknown recipients, spend alarms.	Load test and scripted flood remain inside CPU, DB and cost limits.
Secret exposure	Only API URL is public; DB/provider secrets stay in host secret stores; scanner in CI.	Git history scan and built frontend bundle contain no secret material.
Excess retention	10-60 minute expiry; reads filter by expiry; sweeper deletes; logs and errors exclude message bodies.	Clock-controlled tests confirm expiry and deletion; sampled logs contain no content.

Trust pages that must exist before public launch

- + /privacy - data categories, precise TTL, processors, consent, rights, contact, and last-updated date.
- + /terms - inbound-only purpose, prohibited uses, no delivery guarantee, age/jurisdiction, enforcement.
- + /cookies - categories and controls; no consent-requiring scripts on this policy page [S11].
- + /abuse - monitored contact, required evidence, response targets, law-enforcement channel.
- + /security - architecture summary, responsible disclosure, no public issue reports, 48-hour acknowledgement target.
- + /transparency - uptime, incidents, aggregate deletions/requests, domain lifecycle without publishing active inventory.

Legal note

This report is product strategy, not legal advice. GDPR data minimization/storage limitation, Canadian privacy obligations, CCPA thresholds/rights, cookie rules, ad-tech processor chains, and law-enforcement handling require counsel for the operating entity. California guidance, for example, ties applicability to statutory thresholds and requires specific privacy notices and rights when applicable [S19].

SECTION 07

Website design system from scratch

Preserve the current product's calm minimalism while making the utility immediate, credible, responsive, and brand-consistent.

Experience principles

Principle	Design behavior
Utility before explanation	The first meaningful action is 'Create free inbox'. No email input, account form, hero carousel, or forced tutorial.
Trust before monetization	Show expiry, inbound-only status, images-blocked default, and privacy link beside the tool - not hidden in the footer.
One dominant action	Bright green is reserved for the current primary action. Secondary actions are outlined deep green; destructive actions require confirmation.
Stable attention	Reserve all async regions: inbox empty state, message rows, OTP card, consent surface, and eligible ad slots. No layout jump on delivery.
Mobile is the primary canvas	Address copy, OTP copy, and message open work one-handed; minimum 44px targets; list/viewer becomes a routed stack.
No dark patterns	No fake inbox activity, countdown pressure, deceptive download buttons, ad-like CTAs, forced notification prompts, or hidden consent controls.

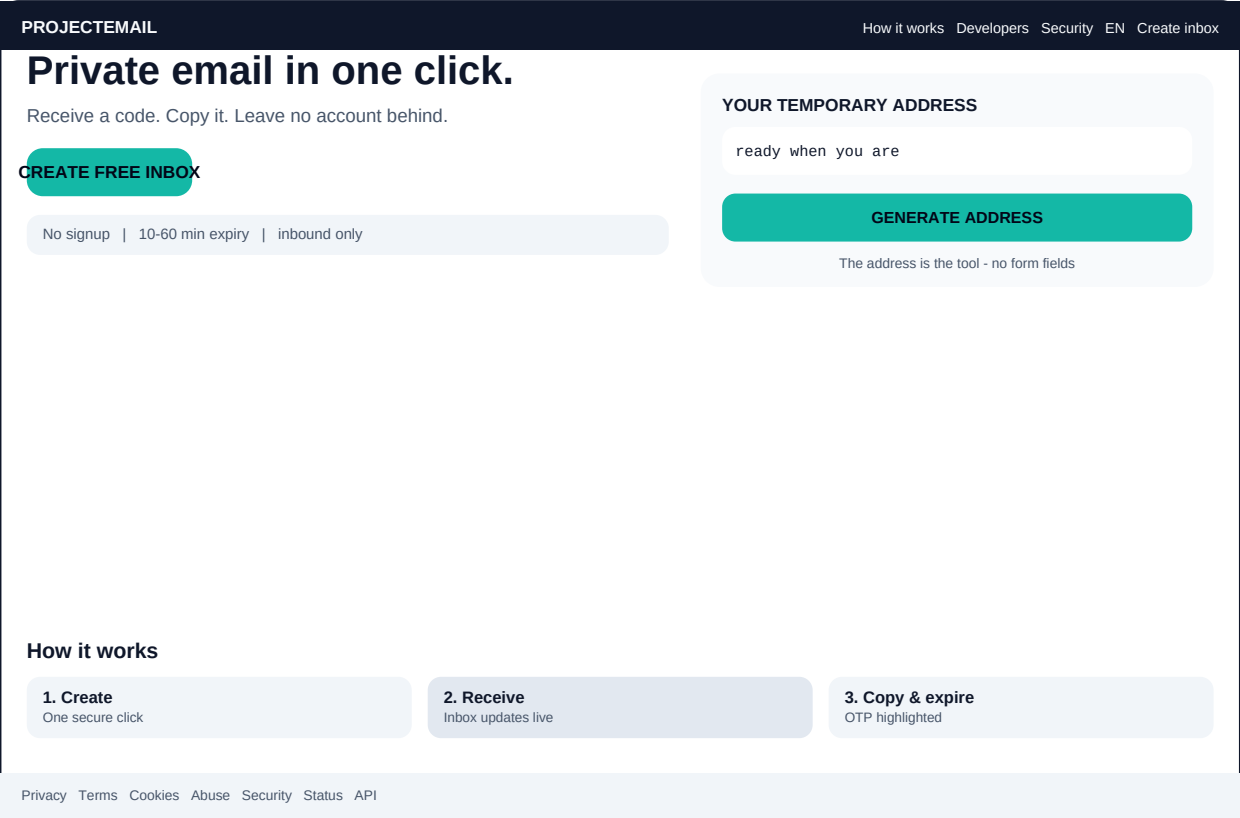
Approved visual tokens

Token	Value	Usage
Primary	#0F172A	Navigation, headings, secure panels, footer.
Canvas	#F8FAFC	Page background and calm privacy framing.
Accent	#14B8A6	Primary CTA, live/verified indicators; dark text #020617.
Panel	#FFFFFF / #F1F5F9	Cards, inbox list, message viewer, content sections.
Text	#0F172A / #475569	High contrast primary and secondary text.
Borders	#CBD5E1 / #94A3B8	Dividers, inputs, card outlines, focus-safe structure.
Type	Space Grotesk -> Inter -> system-ui	Independent ProjectEmail hierarchy that matches the current clean web shell.
Layout	8px base; 12-column desktop; 4-column mobile; max content 1200px	Predictable spacing and reusable responsive grid.

SECTION 08

Homepage design specification

The home page must work as both a useful product and substantial publisher content.

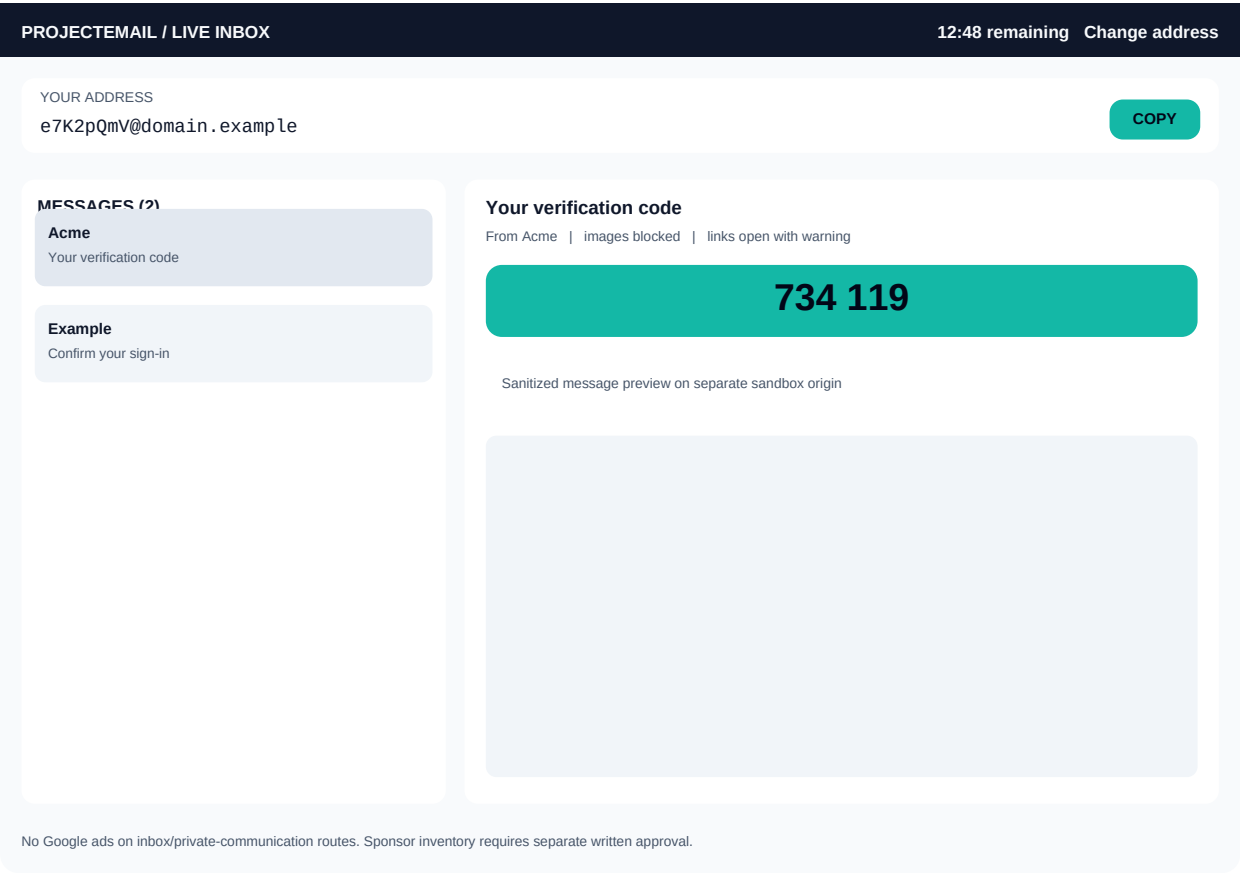


Section	Required content	Build notes
Header	ProjectEmail wordmark; How it works; Developers; Security; language selector; Create inbox.	Sticky only after 80px scroll; keyboard-visible focus; no ad in navigation.
Hero	H1: 'Private email in one click.' Subhead: receive a code, copy it, leave no account behind. Primary CTA.	Server-render headline and explanatory copy. CTA calls API; optimistic state only after success.
Generator card	Idle -> creating -> address -> copy confirmation -> expiry; domain status fallback.	No user input. Announce generated address through aria-live; never put possession token in analytics.
Trust strip	No signup; 10-60 minute expiry; inbound only; remote images blocked.	Each claim links to the exact security/privacy explanation.
How it works	Three steps with real screenshots or simple diagrams.	Visible HTML, not image-only text; include alt text.
Why ProjectEmail	Speed, privacy, OTP extraction, developer testing, transparent limits.	Original proof or measured data only. No fake testimonials or traffic numbers.
Use cases	Privacy, app testing, newsletter trials, QA automation - each links to a substantive guide.	Avoid near-duplicate brand/service landing pages.
FAQ	Is it private? How long does it last? Can I send? Why didn't mail arrive? Are attachments safe?	Useful visible content. Do not expect FAQ rich results; eligibility is limited.
Footer	About, contact, status, security, abuse, legal, API, GitHub, locale links.	Organization identity and policy links support trust and ad review.

SECTION 09

Inbox and message-viewer design

The inbox is a high-trust application route, not an advertising page.



State	UI behavior	Acceptance criteria
Empty / waiting	Address, copy button, expiry, live connection pulse, 'waiting for mail' guidance, provider delay link.	No fake messages; retry/reconnect is automatic and status is announced.
Message arrived	Insert without moving the address/controls; announce sender/subject; unread marker; preserve scroll.	CLS <=0.1; keyboard focus remains where the user left it.
OTP detected	High-contrast OTP card above preview with one-tap copy and 'copied' feedback.	OTP accuracy regression set; no clipboard write before user action.
HTML message	Sanitized preview loaded from sandbox origin; remote images blocked; text-view fallback.	No scripts, forms, nested frames, same-origin privilege, or referrer leakage.
Verification link	Show destination host, open via warning/interstitial, strip referrer.	Dangerous schemes/private-IP URLs blocked; popup always user initiated.
Expired	Explain automatic deletion and offer a new inbox; clear token and local state.	API returns indistinguishable not-found; old URLs are noindex and non-cacheable.
Error / offline	Keep address visible, explain reconnect/backoff, offer refresh and copy support code.	No message data in support code; no destructive automatic address change.

SECTION 10

Information architecture and route contract

Separate crawlable publisher content, private utility routes, and untrusted email content.

Route family	Indexing	Purpose / required design
/	index	Primary tool plus substantial explanation, trust evidence, FAQs, and links into the knowledge graph.
/guides/{slug}	index	Original educational guides with author/reviewer, date, sources, examples, screenshots, related links.
/use-cases/{slug}	index selectively	Only distinct jobs with unique workflows and evidence. Never hundreds of query variants.
/locale/{...}	index after review	Dedicated URL per language; self/cross hreflang plus x-default; fully translated visible content [S4].
/developers, /api, /docs	index	OpenAPI overview, quickstart, limits, security, SDK examples, changelog, status.
/extensions/chrome, /firefox	index	Distinct product information, permissions, screenshots, privacy disclosure, store link.
/about, /security, /abuse, /privacy, /terms, /cookies	index	Trust and compliance pages; policy pages contain no consent-requiring scripts.
/inbox/{id}, /message/{id}	noindex, noarchive	Private app state; token never in page title, logs, referrer, or analytics.
sandbox.projectemail.../message/{id}	noindex + robots disallow	Sanitized untrusted HTML only; restrictive CSP; no app cookies or ad scripts.
/internal, /admin, webhooks, health	not indexable	Authentication/allowlists as applicable; robots is not access control.

Responsive behavior

- + Mobile (<768px): route-like list -> message transition; address bar and OTP copy remain pinned below header; no split pane.
- + Tablet (768-1023px): 38/62 list-viewer split when a message is selected; collapse content guide sidebars.
- + Desktop (>=1024px): 360px message list plus flexible viewer; max 1200px shell; eligible content ads remain outside the app route.
- + Reduced motion: disable ping/pulse animation and transitions; status remains readable as text.
- + WCAG 2.2 AA baseline: keyboard access, visible focus, contrast, reflow, 44px primary targets, no focus obstruction [S14].

SECTION 11

SEO strategy: earn rankings, do not manufacture pages

Search approval is not an application. Eligibility and ranking come from crawlability, value, trust, and demand.

Technical SEO launch checklist

Layer	Implementation	Owner / gate
Canonical origin	Move public brand surface to a custom HTTPS domain. 301 all alternate hosts; self-canonical every indexable page.	B; before Search Console.
Rendering	Static/server-render all public content and metadata. Client JavaScript may enhance the tool but must not hide the core explanation.	B; inspect rendered HTML.
Robots	Allow Googlebot, Bingbot, OAI-SearchBot on public content; disallow sandbox/internal paths; noindex private routes.	B + A security review.
Sitemaps	Only canonical, indexable 200 URLs; accurate lastmod; separate locale/content sitemaps; submit to Google/Bing [S5].	B; CI validates URLs.
Internal links	Home -> hub -> leaf hierarchy; breadcrumbs; related guides based on genuine topic relationships.	B; no orphan pages.
International	Separate URLs, visible full translation, reciprocal hreflang including self and x-default [S4].	B; native review required.
Structured data	Organization on home/about; SoftwareApplication on tool/extension page where visible facts satisfy requirements; BreadcrumbList/Article where accurate [S15].	B; Rich Results test.
Performance	LCP <=2.5s, INP <=200ms, CLS <=0.1 at p75 mobile and desktop; implement real-user monitoring [S13].	B; release budget.
Measurement	Search Console ownership, sitemap/index reports, queries/pages/countries, security/manual-action alerts [S16].	Shared weekly review.

Content pilot: first 32 pages

Cluster	Count	Examples	Unique value requirement
Core utility	4	Temporary email; disposable email; burner vs alias; how temporary inboxes work.	Original product behavior, limitations, and screenshots.
Privacy education	6	Tracking pixels; signup privacy; email aliases; data expiry; safe verification links; threat model.	Cited, reviewer-owned explanations and checklists.
Developer / QA	8	Email testing API; OTP test automation; webhook examples; Playwright/Cypress flows; rate limits; CI use.	Runnable code, OpenAPI links, measured examples.
Troubleshooting	8	Mail delayed; address rejected; inbox expired; image blocked; code not found; sender issues.	Actual support resolution, diagnostics, and next actions.
Use cases	6	QA testing; newsletter trials; privacy on public Wi-Fi; mobile verification; localization testing; demos.	Distinct workflow, not a keyword-swapped page.

Pilot expansion gate

Wait at least 28 days after stable discovery. Expand only if >=80% of the cohort is indexed without quality exclusions, non-branded impressions grow, the median page has meaningful engagement, and no manual/security/publisher issue exists. Otherwise improve, merge, or remove pages - do not add volume.

SECTION 12

GEO and AI-app discovery

Optimize for being understood, grounded, and cited - not for manipulating answer engines.

Signal	Implementation	What it does not guarantee
Crawl access	Allow OAI-SearchBot on public pages; keep noindex/private/sandbox rules separate. Track ChatGPT referrals [S7].	Inclusion, ranking, or a recommendation.
Bing/Copilot foundation	IndexNow for additions/updates/deletions; canonical sitemaps; accurate lastmod; crawlable internal/external links [S6].	A citation in every Copilot response.
Google AI features	Use the same helpful, reliable, people-first content and technical SEO foundation. Do not create fan-out query pages [S3].	Special AI ranking from an 'AI' schema or file.
Answer-first structure	Start guide sections with a direct 40-80 word answer, then evidence, steps, limits, and sources.	Citation if claims are generic or unsupported.
Entity clarity	Consistent ProjectEmail name, organization details, logo, contact, GitHub, product docs, and sameAs links where true.	A knowledge panel or preferred-provider status.
Original evidence	Publish latency/OTP accuracy methodology, status history, privacy design decisions, and API benchmarks using aggregate data.	Authority if data is unverifiable or cherry-picked.
Machine-readable product	OpenAPI JSON, stable docs URLs, changelog, robots, sitemap, Organization/SoftwareApplication JSON-LD.	That LLMs will execute the API or treat schema as endorsement.
llms.txt	Optional convenience index only after public docs are stable; keep it accurate and small.	A recognized ranking standard or approval path.

AI-citation page pattern

Question -> direct answer -> when to use/not use -> numbered steps -> security/privacy note -> measurable limit -> example -> source links -> last reviewed date -> author/reviewer. Keep claims stable, specific, and visible in HTML. Cite first-party standards and your own reproducible data.

Measurement

- + Tag referrals from ChatGPT, Bing/Copilot, Perplexity and other answer engines without identifying message content or inbox tokens.
- + Track cited/linked pages manually each month for a fixed set of 20 real user questions; do not automate query spam.
- + Use Google Search Console's search and generative-AI performance reporting as it becomes available; treat impressions/clicks as outcomes, not average-position vanity [S16].

SECTION 13

Audience and market-entry engine

Attention comes from useful distribution loops, not a one-day launch.

Channel	Asset	Cadence	Success metric	Stop condition
Search	32-page pilot + guides + troubleshooting	2 high-quality updates/week	Non-brand impressions, indexed %, task completion	Quality exclusions or flat demand after two revisions
Developer	Public API, OpenAPI, GitHub examples, SDK starters	1 integration/month	API keys, successful calls, GitHub stars/backlinks	Abuse/support cost exceeds qualified usage
Browser stores	Native extension with create/copy/notify	Release monthly	Approved installs, D7 active, low uninstall	Policy issue or no native utility
Communities	Engineering postmortems, privacy guides, build notes	1 useful post/launch	Qualified referral sessions and feedback	Promotional response / moderation warning
Partnerships	QA tools, test automation, privacy educators	5 targeted outreaches/week	Integration, co-guide, or earned link	Low fit; never buy bulk links
PR / original data	Annual OTP delivery and tracking-pixel report	Quarterly/annual	Citations, media links, branded search	Cannot produce defensible methodology
Affiliate	Clearly labeled privacy-tool cards on eligible content	Test one partner at a time	Net revenue, user complaints, page speed	Trust/UX damage or unclear disclosure

Launch sequence

- + Private alpha: 25 testers from QA/privacy communities; measure delivery, rejection, comprehension, and trust.
- + Public beta: one brand domain, three mail domains, 12 cornerstone pages, status/security/legal surfaces, no Google ads.
- + Developer launch: publish API quickstart, limits, sample Playwright/Cypress tests, and a transparent rate-limit policy.
- + Store launch: Chrome first after native utility is complete; Firefox after shared core is stable; no incentivized installs/reviews.
- + Search/content launch: publish in cohorts, submit sitemap, use IndexNow for Bing, and improve from real query/support data.

SECTION 14

Ad approval and monetization plan

Separate product usefulness from publisher inventory, and design for rejection without killing the business.

Route policy matrix

Route	Google ads	Alternative	Reason
Home / tool	Only after site approval and only if substantial publisher content remains primary; start with none.	Direct sponsor below educational content; affiliate card with disclosure.	A pure tool/non-content screen is high-risk for low-value inventory [S10].
Guides / developer docs	Candidate after approval, consent, ads.txt, content review, reserved slot dimensions.	Direct sponsorship and contextual affiliate links.	Original publisher content can support clear ad association.
Inbox / message list	No.	No ads initially; seek written determination for any non-Google sponsor placement.	Email/private communication is the primary focus [S8].
Message viewer / sandbox	No.	None.	Untrusted content, private communication, isolation boundary.
Browser extension	No AdSense; no ad-first design.	Optional transparent affiliate action tied to real user benefit only.	Chrome policies require usefulness, disclosures, and prohibit AdSense in products [S12].

Approval readiness checklist

- + Custom domain, HTTPS, clear navigation, About/Contact, substantive original content, privacy/terms/cookies, abuse/security, and no under-construction routes.
- + Consent management configured for applicable regions before ads/analytics; use Google's current certified CMP/TCF requirements [S11].
- + ads.txt contains only authorized sellers; seller identity and domain ownership are consistent.
- + No ads near copy buttons, destructive actions, navigation controls, fake download buttons, or more ads than publisher content.
- + No purchased/automated/forced traffic, auto-open, pop-under, incentivized view, or internal team clicking.
- + If GAM refresh is approved, declare exact trigger/interval; prefer user-action/event-driven refresh; test viewability and invalid traffic [S9].
- + Keep a route-level kill switch and policy incident runbook. An ad rejection must not break the inbox.

MCM / AdX reality

AdX access is not an automatic feature of a new AdSense account. Multiple Customer Management is an Ad Manager 360 relationship in which a parent publisher can manage a child account or inventory [S20]. Start conversations early, but never integrate a partner without contract, revenue-share, data-processing, termination, and ads.txt review.

SECTION 15

Track A and Track B ownership

Parallel work with narrow contracts, shared gates, and no duplicated stack decisions.

Track A - Platform & Trust	Track B - Product & Growth
Own backend/, infra/, migrations, provider webhook, domain lifecycle, security controls, rate limits, event broker, observability, reliability, cost controls.	Own frontend/, extension/, public page architecture, design system, accessibility, SEO/GEO, content operations, Search Console/Bing, consent and monetization UI.
Primary outcomes: safe mail receipt, correct expiry, fast delivery, strong isolation, repeatable deploys, no secrets/content leakage.	Primary outcomes: instant task completion, credible brand, crawlable helpful content, quality traffic, store eligibility, policy-safe revenue experiments.
Cannot change: public API contract, retention, sandbox permissions, outbound-only rule, or analytics event payload without shared ADR/approval.	Cannot change: API schemas, token handling, message storage, sandbox origin, consent semantics, or ad routes without shared ADR/approval.
Reviews all Track B PRs touching auth, tokens, iframe, CSP, analytics payloads, provider data, or destructive actions.	Reviews all Track A PRs changing visible API behavior, error copy, response latency, message states, metadata, or public documentation.

Shared contracts decided before parallel coding

- + OpenAPI schemas for create inbox, list messages, message detail, delete/expire, SSE events, and errors.
- + Event names and payloads contain no possession token or message body; version them explicitly.
- + UI state machine: idle -> creating -> live-empty -> live-message -> reconnecting -> expired -> error.
- + Analytics allowlist: page category, action, outcome, latency bucket, locale, consent state; never address, sender, subject, OTP, token, or message ID.
- + Design tokens and route-level monetization flags are versioned, reviewed, and tested.

SECTION 16

24-week parallel roadmap - foundation

Each row is a two-person sprint outcome. Merge only after the shared gate passes.

Weeks	Track A	Track B	Shared exit gate
0-1	Provider/RFC feasibility; webhook contract; threat model; secret/DNS ownership; normalize repo docs and ADRs.	User interviews; brand/IA; responsive wireframes; approval outreach; custom-domain/search plan.	Provider accepted in writing; route policy recorded; backlog and CODEOWNERS agreed.
2-3	Harden inbox create/auth/delete; provider signature/replay checks; expiry sweeper; domain seed/admin path.	Implement design tokens, header/footer, homepage generator states, accessibility primitives, legal/trust-page skeletons.	Create -> receive fixture -> stream -> read -> delete demo; no secret/content in logs.
4-5	Mail parse/sanitize/OTP regression corpus; sandbox content endpoint and CSP; rate/size/message caps.	Inbox list/viewer/OTP copy; mobile routing; empty/error/expired states; sandbox iframe integration.	Security tests pass; p95 local fixture delivery <2s; keyboard/mobile QA passes.
6	Deploy paid/no-cold-start API pilot; health/readiness; Sentry scrub; spend/abuse alarms; restore drill.	Custom-domain public shell; status/security/abuse/privacy/terms/cookies; RUM without sensitive data.	Alpha on 3 domains; 25 invited testers; zero blocker security findings.

Foundation acceptance metrics

Metric	Target	Owner	Method
Mail-to-SSE latency	p50 <750ms; p95 <2s after provider receipt	A	Signed timestamped fixtures + provider events.
OTP extraction	>=95% precision and >=90% recall on reviewed corpus	A	Versioned multilingual regression fixtures.
Create success	>=99.5% excluding explicit rate limits	A	Synthetic monitor.
Task completion	>=70% testers create, receive, and copy without help	B	Consent-safe funnel + observed test.
CWV lab budget	LCP <2.0s; TBT <150ms; CLS <0.05	B	Mobile CI before field data.
Security	0 critical/high; all medium have owner/date	Shared	Threat checklist + dependency/secret scans.

SECTION 17

24-week parallel roadmap - discovery and distribution

Weeks	Track A	Track B	Shared exit gate
7-8	Public API keys, hashing, quotas, error model, OpenAPI, abuse safeguards, integration tests.	Developer hub, quickstart, code examples, first 12 cornerstone pages, metadata, canonicals, sitemap/robots.	API quickstart works from clean machine; all indexable URLs return correct canonical/status.
9-10	Content/API performance support; cache headers; background expiry; domain health checks; provider failover design.	Publish remaining 20-page pilot; Search Console/Bing/IndexNow; Organization/Breadcumb/SoftwareApplication schema where accurate.	32-page cohort live; Rich Results/URL inspection clean; no thin/orphan pages.
11-12	Extension API/session hardening; short-lived recovery state; permission-minimal contract; quotas.	Build native MV3 extension: create, copy, see latest OTP, expiry/reconnect; listing art, privacy disclosure, store QA.	Extension provides native utility, contains no remote executable code or ads, and passes permissions review.
13-14	Aggregate analytics endpoint and privacy-safe event schema; export/error monitoring; cost-per-1k instrumentation.	Answer-first GEO edits; authors/reviewers; source blocks; OAI-SearchBot access; AI-referral measurement; outreach assets.	No sensitive event fields; 20-query citation baseline recorded; first earned links/outreach responses.

Discovery gate at week 14

- + At least 80% of submitted pilot URLs are indexed or have understood, fixable exclusions.
- + Non-branded impressions show demand in at least two clusters; zero manual actions/security issues.
- + Developer docs drive successful API calls from users other than the founders.
- + Extension accepted or has a specific remediable review reason; never duplicate submissions.
- + Pages with weak demand or engagement are improved/merged; no new locale or page factory yet.

SECTION 18

24-week parallel roadmap - monetization and scale proof

Weeks	Track A	Track B	Shared exit gate
15-16	Consent-aware server flags; route monetization allowlist; ads.txt deploy support; policy kill switch; no ad data in mail pipeline.	Certified CMP; content-route ad placeholders with fixed size; ad review package; affiliate disclosure and one partner test.	No ad/analytics before applicable consent; inbox/sandbox/extension contain no Google code.
17-18	Load test one worker; SSE limits; Redis migration ADR/adapters; incident/rollback drills; DB cost review.	Content improvements from queries; original benchmark/report asset; partnership outreach; CWV field monitoring.	Known single-worker capacity and promotion threshold; all CWV green at p75 when sample exists.
19-20	Implement Redis only if threshold hit; multi-worker cross-delivery tests; queue/backpressure; provider failover exercise.	Controlled content/ad A/B tests on eligible routes; no timer refresh unless approved and declared; extension iteration.	No correctness regression; test decision based on task/revenue/trust metrics, not CTR alone.
21-22	Domain lifecycle automation; reliability dashboard; backup/restore and key rotation; abuse-response tooling.	Launch case study/original data; community and partner launch; locale-1 native translation pilot if English gate passed.	Operational readiness review and one successful simulated incident.
23-24	Capacity/cost/security review; scale ADR; technical debt closure; next-quarter reliability plan.	SEO/GEO/content/store/ad economics review; brand/search report; next-quarter acquisition plan.	Go/hold/stop memo using measured traffic, trust, cost and revenue evidence.

Do not scale when

- + Mail reliability, security, deletion, or abuse operations are below gate.
- + Page expansion is driven by keyword permutations rather than distinct user needs and original evidence.
- + Ad approval is absent, policy warnings exist, or invalid-traffic quality is uncertain.
- + Gross revenue rises while task success, direct return, trust, or Core Web Vitals deteriorate.

SECTION 19

GitHub collaboration system

Two collaborators move quickly by reducing merge risk, not by working in the same files.

Rule	Implementation
Pull before work	Every new task starts with git pull --ff-only and a clean status check. If local changes exist, resolve ownership before pulling/merging.
Branches	feat/a-mail-provider, fix/a-token-auth, feat/b-home-design, feat/b-seo-foundation. Never long-lived personal branches.
Ownership	CODEOWNERS: A for backend/ infra/ migrations; B for frontend/ extension/ public content; both for .github/, ADRs, security, data/analytics/ad contracts.
Issues	One outcome per issue with owner, tier, route/component, security/privacy/policy flags, acceptance tests, and evidence links.
PR size	Prefer <400 changed lines excluding generated files; separate refactor, feature, content, and migration changes.
Review	At least one collaborator approval. Two approvals for migrations, auth/token, CSP/sandbox, provider/webhook, consent, ads, DNS, retention, or CI secrets.
Contract first	OpenAPI/event/design token change lands before dependent implementation; generate types, never hand-duplicate API shapes.
CI	Backend lint/types/tests/migration check; frontend Biome/types/build/unit/e2e; secret/dependency scan; link/metadata/sitemap checks; Lighthouse budgets.
Merge	Squash conventional commit; main must stay deployable; Pages build and API deploy report status; tag milestone releases.
Push when complete	After tests and review, push branch/merge through GitHub. Do not leave finished work only on one computer.

PR template - required answers

Outcome; routes/contracts changed; test evidence; security/privacy/ad/SEO impact; rollback; screenshots at 390/768/1440 for UI; migration lock/data risk; follow-up issue.

SECTION 20

Quality and approval test plan

Approvals are easier when the product is complete, transparent, fast, and testable.

Suite	Must cover	Release gate
Unit	Address entropy, token hash/verify, MIME charsets, sanitizer allowlist, bounded OTP/link extraction, expiry, quota math.	100% on security-critical services; no flaky time tests.
API integration	Create/auth/read/delete/expire, webhook signature/replay, unknown recipient drop, message cap, SSE reconnect/keepalive.	All responses match OpenAPI; error uniformity preserved.
Browser E2E	Generate/copy, live arrival, OTP copy, offline/reconnect, expiry, mobile list/view, keyboard, reduced motion.	Chrome/Firefox/WebKit; 390/768/1440 viewports.
Sandbox security	Script/form/frame removal, remote image default, CSP, origin isolation, link warning, referrer policy.	Any origin escape or content execution blocks release.
SEO	200/indexability, title/meta/canonical/hreflang, sitemaps, robots/noindex, structured data, internal links, custom 404.	No wrong-canonical, orphan, duplicate, or private URL in sitemap.
Performance	Static public routes, generator hydration, inbox updates, ad/CMP scripts, extension popup.	CWV targets [S13]; budget regression blocks release.
Abuse/load	Creation bursts, webhook floods, oversize MIME, slow SSE clients, DB unavailability, provider retry storm.	Limits fail closed without denial-of-wallet.
Policy/manual	Content completeness, ad-route scan, consent state matrix, ads.txt, extension permissions/listing, legal links.	Signed checklist before every external submission.

Website approval package

- + One-page architecture and route map, privacy/data flow, screenshot set, test results, uptime/status, legal pages, ownership/contact details.
- + For ad partners: exact monetized routes and formats, traffic sources, consent design, invalid-traffic controls, sample pages, ads.txt identity.
- + For browser stores: single-purpose statement, minimum permissions explanation, privacy disclosure, feature video/screenshots, reviewer test inbox.

SECTION 21

Measurement system and decision dashboard

Measure whether users complete the job and trust the tool before measuring ad yield.

Layer	Metric	Target / decision use
Reliability	Create success; provider receipt -> SSE p50/p95; SSE reconnect; error rate	>=99.5%; p95 <2s; investigate by provider/domain without message content.
Utility	Create -> first message; OTP detect/copy; time to copy; task completion	Improve the shortest successful path; segment by device/locale only.
Trust	Privacy/security page visits; image-load opt-in; delete use; complaints	Watch for misunderstanding and reduce surprise.
Search	Indexed cohort %, impressions, clicks, CTR, query/page/country, branded vs non-branded	Search Console is source of truth for search; do not optimize only average position [S16].
GEO	AI referrals; cited/linked pages; 20-query manual benchmark	Monthly trend; focus on accurate citations and qualified use, not mention count.
Extension	Approval, install, activation, D7/D30 active, uninstall, permission complaints	Native utility and trust; no incentivized metrics.
Economics	Eligible content sessions, consent rate, fill, viewability, net eCPM after share, affiliate EPC	Route- and geography-specific; compare to support/performance cost.
Abuse/cost	Unknown-recipient drops, rate limits, provider rejects, DB/API cost per 1k created inboxes	Hard budget alarms and promotion gates.

Privacy-safe event example

```
{"event":"otp_copied","route":"inbox","device":"mobile","locale":"en","latency_bucket":"1-2s","consent":"analytics_yes"}
```

Never include address, inbox token, sender, subject, message ID/body, OTP, destination URL, or raw IP.

SECTION 22

Budget and revenue reality

Use a model that survives ineligible routes, adblock, consent loss, revenue share, and global traffic mix.

Founder-built 24-week cash planning range

Category	Planning range (USD)	What to validate
Domains, DNS, email provider	\$500-\$3,000	Provider pricing/limits, 3 pilot mail domains, brand/sandbox domains, renewal/recovery.
Hosting, Neon, monitoring, WAF	\$300-\$2,500	Paid no-cold-start API before public launch, spend caps, real message and connection volume.
Legal/privacy/abuse review	\$1,500-\$6,000	Entity/jurisdiction, privacy/consent, terms, provider contracts, law-enforcement process.
Native translation/review	\$500-\$4,000	Only first proven locale cluster; do not buy 25-language bulk translation.
Ad ops / MCM / policy consultation	\$1,000-\$5,000	Written route determination, contract/share, consent, ads.txt, refresh terms.
Testing/design/content support	\$500-\$5,000	Accessibility, security test, illustrations/screenshots, original research asset.
Total cash excluding founder labor	\$4,300-\$25,500	Request quotes; commit in gates, not all at week 0.

Scenario model - illustrative, not a forecast

Monthly sessions	Eligible content share	Served imps / eligible session	Net eCPM	Illustrative display revenue
350,000	25-45%	1.2-1.8	\$0.50-\$1.50	\$53-\$425
1,800,000	30-50%	1.4-2.0	\$0.50-\$2.00	\$378-\$3,600
8,000,000	35-50%	1.5-2.2	\$0.50-\$2.00	\$2,100-\$17,600
21,000,000	35-50%	1.6-2.2	\$0.50-\$2.00	\$5,880-\$46,200

Formula: sessions x eligible share x served impressions per eligible session x net eCPM / 1,000. Ranges are management assumptions to be replaced by real 30-day data. Affiliate/direct sponsorship is additive only after refunds, reversals, and user-trust impact are measured.

Investor claim rule

Present three measured scenarios with assumptions and sensitivity. Never reuse competitor traffic estimates, unverified eCPMs, or a 95% margin claim as fact. The milestone is proving repeatable task success and qualified organic acquisition, not defending the original spreadsheet.

SECTION 23

Risk register and stop/go triggers

Risk	Likelihood / impact	Early signal	Mitigation / trigger
Google ads prohibited on core route	High / High	Policy language or written rejection	Route-split from day one; affiliate/direct/content-route economics; stop ad-specific engineering without approval.
Mail domains blocked rapidly	High / High	Delivery failure by sender/domain	Multiple monitored domains, drain/retire, provider reputation, brand domain separate; never promise universal acceptance.
Provider rejects use case or volume	Medium / High	Contract/support response, retry/reject data	Written approval; second-provider proof; dedicated SMTP only after ops capacity.
SEO pilot not indexed/ranked	Medium / High	Quality exclusions, no non-brand impressions	Improve/merge; original research; earn links; stop page multiplication.
Abuse/fraud overwhelms service	High / High	Unknown recipient flood, complaints, provider alerts	Drop early, rate/size caps, Turnstile, monitored abuse, law-enforcement policy, provider cooperation.
MVP one-process event loss at scale	Certain at multi-worker / High	Need for second worker/server	Redis adapter and cross-worker tests before changing WEB_CONCURRENCY.
Privacy or content leak	Low / Critical	Token in analytics/logs, sandbox escape	Allowlist events, scrub logs, CSP/origin tests, two-person approval; immediate incident response.
Two collaborators collide	Medium / Medium	Large PRs, repeated conflicts, undocumented contract changes	CODEOWNERS, track boundaries, contract-first PRs, weekly integration demo.
Design/ad scripts damage CWV	Medium / High	Field LCP/INP/CLS regress	Reserved dimensions, delayed third-party scripts, budgets, kill switch, route-level tests.

Go / hold / stop

- + **Go:** security/reliability gates pass, pilot search shows demand, provider accepts the use case, and unit cost is understood.
- + **Hold:** technical product works but approval, indexation, or monetization evidence is incomplete; improve proof without scaling inventory.
- + **Stop/pivot:** core providers refuse, abuse cannot be contained, privacy controls fail, or qualified acquisition costs more than realistic lifetime value.

SECTION 24

First 14 days - exact next actions

This is the shortest path from placeholder to a credible private alpha.

Day	Track A	Track B	Shared proof
1	Audit pulled code, tests, migrations, env/secrets, docs drift.	Audit live page, routes, metadata, accessibility, custom-domain needs.	One issue board and baseline report.
2	Write provider/webhook and sandbox ADRs.	Finalize IA, homepage/inbox mobile-desktop wireframes, copy hierarchy.	Approve contracts and non-negotiables.
3	Contact 2 inbound providers with honest use-case/volume questions.	Contact ad/MCM partners for route determination; choose brand domain shortlist.	Written external-risk tracker.
4-5	Webhook signature/replay tests; expiry deletion job; token/delete route gap.	Implement tokens/theme/header/footer/home generator shell.	End-to-end UI uses generated API types.
6-7	Sanitizer/CSP/sandbox fixtures; mail/OTP corpus.	Implement inbox states, OTP copy, viewer shell, responsive behavior.	Security demo with malicious fixtures.
8-9	Deploy sandbox/provider test endpoint; log scrubbing and alarms.	Build privacy/security/abuse/status pages and analytics allowlist.	No sensitive data in bundle/logs/events.
10	Run API/security/load smoke tests.	Run keyboard/mobile/CWV/metadata tests.	Fix all blockers.
11-12	Seed 3 controlled mail domains and provider test matrix.	Write first 4 cornerstone pages and technical SEO base.	Private alpha release candidate.
13	Observe 10 tester mail sessions.	Observe 10 tester product sessions; record confusion and copy/design gaps.	Prioritized findings, no vanity feedback.
14	Reliability/security review.	UX/discovery/approval review.	Go/hold memo and next 2-week sprint.

The single most important next decision

Choose and obtain written acceptance from the inbound-mail provider. Without reliable mail ingress, the UI, SEO, ads, extension, and investor narrative are all demonstrations of a service that cannot yet perform its core job.

SECTION 25

Research sources and evidence notes

Primary official sources were preferred for policy and technical claims. Accessed 27 August 2026.

ID	Source	URL
S1	Google Search spam policies - doorway and scaled content abuse	https://developers.google.com/search/docs/essentials/spam-policies
S2	Google guidance on generative-AI content	https://developers.google.com/search/docs/fundamentals/using-gen-ai-content
S3	Google guide to optimization for generative-AI features	https://developers.google.com/search/docs/fundamentals/ai-optimization-guide
S4	Google localized versions and hreflang	https://developers.google.com/search/docs/specialty/international/localized-versions
S5	Google build and submit a sitemap	https://developers.google.com/search/docs/crawling-indexing/sitemaps/build-sitemap
S6	Bing Webmaster Guidelines - search, Copilot, grounding, IndexNow	https://www.bing.com/webmasters/help/bing-webmaster-guidelines-30fba23a
S7	OpenAI Publishers and Developers FAQ - OAI-SearchBot	https://help.openai.com/en/articles/12627856
S8	Google AdSense program policies - email/private communication placements	https://support.google.com/adsense/answer/48182
S9	Google Ad Manager - declare refreshing inventory	https://support.google.com/admanager/answer/6286179
S10	Google Publisher Policies - inventory value and low-value screens	https://support.google.com/adsense/answer/10502938
S11	Google CMP and EU user consent guidance	https://support.google.com/adsense/answer/7670013
S12	Chrome Web Store program policies	https://developer.chrome.com/docs/webstore/program-policies/policies
S13	Google web.dev - Core Web Vitals thresholds	https://web.dev/articles/vitals
S14	W3C Web Content Accessibility Guidelines 2.2	https://www.w3.org/TR/WCAG22/
S15	Google structured data general guidance and SoftwareApplication	https://developers.google.com/search/docs/appearance/structured-data/sd-policies
S16	Google Search Console getting-started and performance guidance	https://developers.google.com/search/docs/monitor-debug/search-console-start
S17	Neon connection pooling and PgBouncer	https://neon.com/docs/connect/connection-pooling
S18	Redis EXPIRE and Pub/Sub references for the scale transition	https://redis.io/docs/latest/commands/expire/
S19	California Attorney General CCPA overview and thresholds	https://oag.ca.gov/privacy/ccpa
S20	Google Ad Manager Multiple Customer Management	https://support.google.com/admanager/answer/11130475

SECTION 25 / EVIDENCE CONTINUED

Repository and supplied-source evidence

- + Supplied PDF: *Disposable Email Platform - Investor Business Plan & Ad Optimization Strategy*, 4 pages, created 27 August 2026.
- + ProjectEmail repository: README.md, CLAUDE.md, docs/VALIDATION.md, ROADMAP.md, ARCHITECTURE.md, SECURITY.md, DATABASE.md, DEPLOYMENT.md, ADRs 0001-0003, backend/frontend code, and Pages workflow at commit 6653b14.
- + Live baseline: ProjectEmail GitHub Pages placeholder observed on 27 August 2026.

Evidence boundary

Approval, indexation, ranking, AI citation, traffic, ad fill, eCPM, store featuring, and profitability cannot be guaranteed. Policy pages change. Re-check the linked primary sources before every external submission and record the version/date in the GitHub issue.